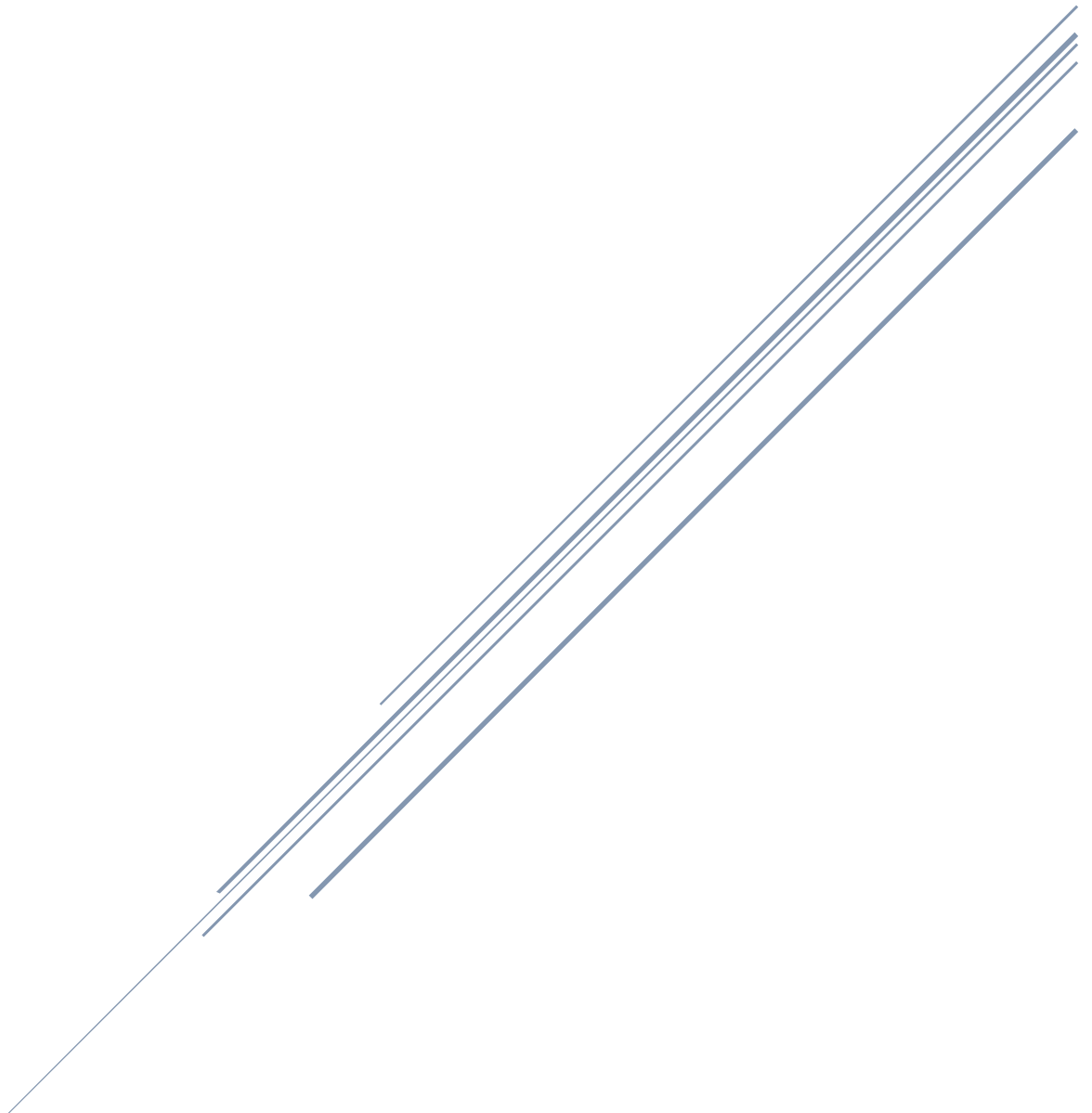


RISK ASSESSMENT DOCUMENT

Lawren Malloch

(Auditing and Security Review)



Toolbox International Limited
Security Department

Tool-Box International Limited.

Tool-Box International Limited is a collective of individuals working mostly in Lagos State, Nigeria, to improve the artisan marketplace. Additionally, we conduct business through our offices in Abuja, Port Harcourt, Benin, Ilorin, Aba, Kano, and Kaduna, as well as other significant towns in Nigeria. We have increased our presence in Africa by extending our commercial activities to places like Accra and Johannesburg.

Tool-Box is a marketplace or artisan marketplace type of company, and we are the middlemen between the artisans and the customers. We try as much as possible to bridge the gap that exists between the two parties. Our major product is our mobile app (for both IOS and Android) and our website, where customers can get artisans of different kinds in their comfort zone and at a lower cost.

We operate to bridge the gap between house owners (in Nigeria and Africa) and good artisans, which includes carpentry, plumbing, mechanics, electricians, tailors, and hair stylists. Our vision is to see every homeowner satisfied with every service brought to them by an artisan and to make sure every artisan in Africa is valued appropriately.

With more than 600 workers (staff) across Africa, we are a sizeable company. Information technology (IT), human resources, accounts (finance), corporate communications, and administrative personnel are some of our departments operating within the company.

We create a unique and supportive ecosystem where artisans can reach a worldwide audience, and at the same time, clients get a distinctive service experience through our technologies, which include an E-commerce Platform (A robust online marketplace platform that allows artisans to list their products, manage orders, and interact with customers). Secure payment gateways for effective and safe transaction handling. A search algorithm tool(resources) that helps customers and clients locate goods of interest and a recommendation tool that suggests related products to customers. We have mobile apps to facilitate easy access and transactions for both artisans who render services and sell goods, and customers who buy goods from them and require the services of an artisan. Support Systems for managing feedback, refunds, and questions from both artisans and customers who use our services.

We also involve the services of third-party companies to help in running the company smoothly without any drawbacks.

IT Infrastructure

The IT department of our company is an essential part of the company, and the ability of the company to function depends totally on our IT infrastructure and the department at large. Behind the scenes, our IT staff and personnel make sure that our different offices and locations (sites) are in line with our corporate strategy by guaranteeing seamless operations and consistently excellent customer service across all of our online platforms.

We currently run our mobile application (IOS and Android) servers, we also run our web servers and email servers at our physical buildings and our employees and staff must use the

company's laptops and PCs to access our servers to reduce the risk of cyber attacks (That's the best we could do at that time).

We make sure our bandwidths are sufficient for the type of work we conduct and that our network connections are reliable and visible to our employees.

RISK ASSESSMENT

Step 1: Information Value

The information we possess is crucial data for customers and artisans. Information like the Full name of both parties, Identification card, payment information (credit card details) of both parties, home/office addresses, and email addresses, pictorial images of artisans and customers that register and use our services.

Company Information includes the name of the company, address, legal documents, and registration number, statements on finances, details of bank account and operations, details about each employee, such as their biographical information, work history, job functions, pay slips, and benefits, information regarding the IT infrastructure, such a network setup, gear(hardware) inventories, and software licensing.

Therefore, with all the information listed out, they are all **Highly Valuable** to the company. If any of the listed information gets leaked or stolen it can cause serious damage to the company's operations and reputation (which is very necessary for this kind of business), and yes suffer downtime if information like payment information of our customers (both artisan and customers) are stolen and it also depends on how many get compromised at the same time.

Step 2: Prioritizing Assets

- The Data of Customers (Artisans and customers)
- The Software (server)
- The Trust of users of our services.
- Company Information

The number one asset, according to level of importance to us as a firm is the **data** of our wonderful customers; if this is tampered with it can affect the operations of the company and also affect our reputation. The **trust of our users** is next on our priority list, losing this can cause a drawback on the company's progress. **The toolbox App** is the foundation of our business; it helps our customers interact with each other and where all the business activities happen. If affected can cause downtime in our operation and therefore cause several other damages and financial loss. **Company information** is also a valuable asset to the company, if stolen can cause financial expenses that are not planned for.

Step 3: Possible Cyber Threats

Possible Natural Disaster (flood), Unauthorized access, insider threat, poor backups (leading to loss of data), Human error (lack of proper training of staff), system failure, poor Incident response plan and response systems, and phishing emails. These are the cyber threats that have been identified during this assessment, they can individually cause great damage to the company if not taken care of.

Step 4: Identified Vulnerabilities

We are currently dealing with some vulnerabilities; a lack of proper training of staff and natural disasters (floods) which can be classified as a physical vulnerability. A former staff of the company still can access the servers used by Tool-Box, which can lead to loss of data and reputation damage.

System failure and poor backup systems can be classified into this category because it has to do with our systems (servers) failing at different points. Our system tends to fail when it is not taken care of or when it is overloaded more than its current capacity. The Company is associated with poor backup systems and tends to lose vital data when a cyber breach incident occurs. Our data becomes susceptible when backup software is not patched and updated regularly.

Other vulnerabilities that can be exploited in our company are; phishing emails and poor incident Response plans.

Step 5: Controls

Preventive Measures: There are simple and frequently erratic measures in place at the company, they include, the usage of basic antiviral software, basic password restrictions without the use of multifactor authentication, and ad hoc training sessions to increase awareness.

Detective Measures: The measures used by Toolbox are restricted and unofficial. We rely on basic activity recording and checks, intermittent security audits, and periodic manual inspections. Reactive detection frequently finds problems only after they have had some effect on the company.

Corrective Measures: We deal with problems as they come up, frequently offering short-term rather than long-term answers. We lack Formal incident response, which could lead to uneven reactions to vulnerabilities and security breaches in our space.

Generally, we have minimal, erratic, and frequently reactive safeguards against risks. Usually, the emphasis is on dealing with problems after they arise rather than averting them altogether.

Step 6: Likelihood and Impacts of Scenarios

Toolbox can lose millions of dollars due to the value of clients' data and information and company information that we possess and handle, suits and other legal repercussions can further increase the cost that would be incurred as a result of any cyber breach.

The image (reputation) of the company can be affected or destroyed cyber breach should happen through any of the threats or vulnerabilities listed above, and in turn, the confidentiality, Integrity, and availability of our service and systems will be questioned and later on affected.

We will lose a huge amount of time (business time) if any of the vulnerabilities should be exploited because of the time that will be required to address and fix the issues brought about by any breach on Tool-Box, making us focus less on regular business operations and experience some operational disruption. And can result in weeks of disruption and divergence from regular business activities.

RISK MATRIX				
	Low Little impact	Medium The impact is notable but not critical to remediate	High Serious impact and should be remediated immediately	Critical This could lead to a disaster.
Impossible Risk unlikely to occur.			1. Poor backups (leading to loss of data)	1. Insider Threat
Possible Risk might occur		1. Natural Disaster (Flood)	1. Physical Vulnerability 2. Human error (lack of proper training of staff)	1. Poor IRP
Probably Risk will occur		Phishing Emails	1. System Failure	1. Unauthorized Access

Step 7: Prioritizing Risks

Based on the list of identified threats and vulnerabilities the company has, they will be prioritized into 3 categories (Critical, High, and Medium).

Critical risk: Insider Threat, Poor Incident Response Plan, and Unauthorized access. Considering factors like the Cost the company can incur if any of these are exploited, time and the reputation of the company are at risk of being damaged.

High risk: Human error (lack of proper training of staff), System Failure, and Poor backups (leading to loss of data). Risk that has a high probability of happening and having a high negative impact. These are prioritized because, should they come to pass, they could cause serious harm to the organization's operations (activities), image, and finances.

Medium Risk: Natural Disaster (flood), and Phishing emails. These risks possess a moderate degree of potential influence and a likelihood of happening, they may not be as important as the rated risk and critical rated risks, but medium-rated risks nevertheless need to be managed to keep them from getting worse. They are important enough to justify monitoring and mitigation.

COBIT

RISK	CURRENT CAPABILITY LEVEL	TARGET CAPABILITY LEVEL
Unauthorized access	Level 1 (Initial or intuitive)	Level 4 (Predictable)
Insider threat	Level 2 (managed)	Level 4 (measured and controlled)
Poor backups	Level 2 (Established)	Level 5 (Optimized)
Human error	Level 1 (Initial or Intuitive)	Level 4 (measured and controlled)
System failure	Level 2 (managed)	Level 5 (Optimized)
Poor Incident Response Plan	Level 1 (Initial or Intuitive)	Level 4 (measured and controlled)
Phishing emails	Level 2 (managed)	Level 5 (Optimized)
Natural disaster (Flood)	Level 3 (Defined)	Level 4 (measured and controlled)

Why we are at Level 1 and Level 2: Toolbox operates at this level of capability because the processes and controls in place are ad hoc, inconsistent, and poorly documented. Ineffective incident response and human error results from a lack of consistent training and awareness initiatives. Unreliable backups and other security procedures are the reasons why we experience inadequate monitoring and validation.

Toolbox is exposed in the absence of a systematic incident response plan and preventative actions to deal with risks like phishing emails and natural disasters. The company is unable to achieve greater capability levels as a result of these shortcomings and drawbacks, which collectively lead to a reactive rather than proactive approach to IT and security management.

How we plan to get to our Target Level: Our target capability level for each of the risks mentioned is Level 4 (Predictable) and Level 5 (Optimized) and to get to that level of capability will require some processes to take place. First and foremost, the emphasis is on creating and recording official policies and procedures. We must endeavor to give our employees regular training on these procedures to guarantee that everyone is aware of and complies with them. To proactively identify and address risks or system problems, we put advanced monitoring technologies into place.

We must then implement continuous improvement procedures and frequent review cycles. This entails carrying out post-event assessments and audits as well as modifying plans in light of new information. Phishing simulations, incident response exercises, and routine backup testing all aid in improving their readiness and reactivity. Another important step we will be taking is to integrate automation wherever possible to improve productivity and decrease human error.

Getting to the capability levels we want, will require a proactive strategy that uses data and analytics to anticipate problems before they arise, which promotes a culture of ongoing learning and adaptation.

CIS Controls

Control 1: Inventory and control of Hard Assets

Sub control 1: Deploy Port Level Access Control: Using a Port Level Access Control will help control and restrict which devices are allowed to connect to the network. To guarantee that only authorized devices can connect to the network, the authentication system must be linked to the data from the hardware asset inventory. This control helps reduce the risk of allowing or giving access to unauthorized individuals, thereby reducing unauthorized access to our network.

An example of this is using 802.1X, a network access control protocol. Set up a RADIUS server to manage requests for authentication into the company's network. Devices attempting to join the network will have their credentials verified by this server.

Metric: The number of blocked attempts at illegal access. This indicates how well the control is working to stop unauthorized access.

The percentage of network ports protected by 802.1X: This indicates how widely the control has been implemented.

Sub control 2: Maintain Asset Inventory Information: This involves the company keeping accurate and detailed records of every asset that a company owns. Software, data, hardware, and virtual resources are examples of our company's assets. This control involves the company IT department ensuring that each asset's address of hardware, network address, name of machine, department, and whether or not the hardware asset has been authorized to connect to the network.

An example will be, maintaining a detailed inventory of all our assets to ensure maximum security and management.

Metric: Inventory Accuracy Rate; To the total number of assets that ought to be listed, this statistic calculates the proportion of assets that are accurately recorded in the inventory.

Sub control 3: Utilize Client Certificates to Authenticate Hardware Assets: The use of each client certificate (digital certificates) to check and authenticate assets trying to connect to the company's network.

Example: Issue digital (clients) certificates to each laptop and server (user) and when an asset tries to connect to the network, it presents the certificate assigned to it. Then the certificate is verified and then it is given access to the network by the network access control system if the certificate is verified and okay.

Metric: Certificate Authentication Coverage Rate, the percentage of client certificate-authenticated hardware assets. Which lowers the possibility of unwanted access by guaranteeing that a sizable percentage of hardware assets are safely authenticated.

Control 2: Email and Web Browser Protections

Sub control 1: Ensure Use of Only Fully Supported Browsers and Email Clients: This control is essential in reducing phishing emails, it is making certain (sure) that only fully compatible email clients (addresses) and web browsers, the most recent and updated versions offered by our vendors are permitted to operate within the company.

Example: The use of the company's authorized email address (daviddam@toolbox.com) for communication and access to information and data.

Metric: Compliance Rate for Email Clients and Supported Browsers, lowers the possibility of vulnerabilities by making sure that all systems are running safe, current software.

Sub control 2: Sandbox All Email Attachments: A secure and isolated environment for opening and examining emails and attachments that come with them without endangering the computer or the network it is connected to. This will help our employees stay clear of any malicious email that includes attachments aimed at gaining access to the company's network.

Example: The use of an MX layer sandboxing tool that provides a comprehensive defense against malware, phishing emails, and APTs.

Metric: Time to Detect and Mitigate Threats: evaluates how well the sandboxing tool detects and eliminates risks in a timely manner while causing the least amount of harm to the company. These metrics aid in assessing the MX layer sandboxing tool's efficacy and efficiency in offering thorough protection against a range of email-based threats.

Sub control 3: Use of DNS Filtering Services: This control will help block access to known malicious domains. This service will act as a regulator and checkpoint that regulates which websites are accessible by the company's pre-established security and policy standards that govern the network.

Example: The company employs the services of SafeDNS or Cloudflare Gateway to implement this control, to create a safer work environment for the employees.

Metric: Threat Prevention Rate: the proportion of threats (phishing attempts, dangerous websites, etc.) that are stopped by Cloudflare Gateway or SafeDNS before they have a chance to harm users of the company's website.

Control 3: Data Recovery Capabilities

Sub control 1: Ensure All Backups Have At least One Offline Backup Destination: This control will ensure that the company has a secured backup destination known to only the management group and top IT officials, this will help in increasing the protection of the company's data and also aid in the development of Incident Response Plan.

Example: Having a destination that is not reachable by hackers and employees through the network to store vital information.

Metric: Recovery Time from Backups operating Offline and Offline Backup Check Rate for Integrity.

Sub control 2: Perform Complete System Backups: For Toolbox to facilitate the speedy recovery of a whole system, we need to make sure that all company critical systems and servers are backed up as a whole using and adapting procedures like imaging. Also, ensure that every system data is automatically backed up regularly.

Example: The company should make sure that every data and server used by the employees and the company at large should have a backup system to prevent loss of data.

Metric: A system put in place to measure the success rate of backups that are completed without errors.

Sub control 3: Protect Backups: This control will help the company secure and protect backup systems through physical security or via encryption when storing them, also making sure they are protected when they are moved through the network. This control will involve cloud security services and remote backups.

Example: The use of AES -256 (Advanced Encryption System) to encrypt their backup systems because it is now for its high-security level.

Metric: Performance Impact of the Encryption: calculates and measures the performance cost that AES-256 encryption causes when backups are being made.

Control 4: Implement a Security Awareness AND Training Program

Sub control 1: Implement a Security Awareness Program: Toolbox should ensure that a security awareness program is provided that all employees must regularly complete to make sure they comprehend (fully understand) and demonstrate the behaviors and abilities needed to contribute to the organization's security. The campaign should be presented and delivered interestingly and consistently.

Example: Sponsor and organize Initial training for new hires that covers basics of cybersecurity, host monthly webinars for staff about trending and important topics like, phishing attacks and the use of state internet.

Metric: Reduction in security Incidents, the drop in security occurrences during a given time frame following the security awareness program's implementation.

Sub control 2: Deliver Training to Fill the Skills Gap: We will suggest a training program to fill the gap in cyber security processes and procedures so as to increase advanced cybersecurity skills, and foundational skills for cyber security and security in general. After successful identification of the "skills gap", They should provide efficient training to close the gap and improve employees' security-related behavior.

Example: Conduct courses that teach essential and fundamental topics like white hat hacking (Ethical Hacking), incident response, and network security.

Metric: Skills Assessment Improvement, the typical difference between pre- and post-training scores on skills assessments.

Sub control 3: Train Workforce on Sensitive Data Handling: This control will help with training staff and employees on how to transfer data, store data properly, and destroy sensitive information that is not needed again.

Example: conducting seminars on the best storage system to use and the best ways of destroying data when not in use, the best ways of dealing with data-in-transfer, data-at-rest, and data-in-use.

Metric: Regular test and exams should be conducted to know how well the employees have improved towards data handling.

Control 5: Incident Response and Management

Sub control 1: Document Incident Response Procedures: These controls will involve the company ensuring that there are documented incident response plans that outline staff responsibilities and the stages of incident handling and management. Also, creating a thorough strategy that specifies how Tool-Box will identify, address, and recover from security issues.

Example: Develop a well-written and organized response plan.

Metric: The amount of time that passes between written procedure reviews and modifications. This will guarantee the regular examination and updating of established procedures to reflect current practices and possible shifts in the hazard situation.

Sub control 2: Assign Job Titles and Duties for incident Response: This will involve assigning particular people (employees) job titles and responsibilities for managing the network system, and computer and making sure that tracking and documentation are maintained from the beginning of the attack or breach to its conclusion. It assigned different roles to individuals to make sure the developed incident response plan was followed and kept updated.

Example: Assign an Incident Response Manager who will oversee and manage the entire process and make sure every team and their members are coordinated.

Metric: The rate at which the team is satisfied, the proportion of team members who, according to surveys or comments, are happy with the coordination and leadership of the incident response manager.

Sub control 3: Create Incident Scoring and Prioritization Schema: This company will make a schema for incident grading because of the size of the company (implementation group 3) and prioritizing based on the known or possible effects on the company.

Example: Assigning scores to the level of impact, like Low, Medium, and High.

Metric: The mean time that it will take to respond to incidents based on their different priority levels.

PIPEDA

1. **Accountability:** A person or group will be assigned to oversee the organization's PIPEDA compliance. All privacy policies and procedures will be documented and upheld by this team. Also, to make sure we are responsible for the personal data our clients give us, we will make sure we adhere to standards like PCIS-DSS.
2. **Identifying Purposes:** At the time of collection, clearly state and record the reasons why personal data is being gathered. Inform the people from whom the information is gathered or collected. Before using our Toolbox app and website, we will require our clients to read and sign a terms and agreement form, which will serve as documentation of our information collection goals.
3. **Consent:** Our clients will be required to read and sign terms and agreements confirming that they understand and consent to our use of their data. Before customers may access our website and application and make a request on artisans registered with us, this will be completed. We will make sure people understand what they are consenting to and that their consent has meaning.
4. **Limiting collection:** We will only gather the personal data required to fulfill the stated objectives. And stay clear of gathering unnecessary or irrelevant data.
5. **Limiting Use, Disclosure, and Retention:** Unless agreement is acquired for other uses, we will use and disclose personal information solely for the purposes for which it was collected. Only keep personal data as long as is required to achieve those goals, after which it should be safely disposed away.

6. **Accuracy:** Toolbox will make sure all personal data of clients is correct, comprehensive, and current. Establish procedures that allow people to update their data as needed.
7. **Safeguards:** We will take great care to safeguard the private information of our clients. Our websites will be encrypted, and we'll make sure that our Toolbox database has a strict password policy. We also guarantee the hashing of our clients' passwords.
8. **Openness:** We will Provide people (clients especially) with easy access to information about our company's privacy practices and policies. This will cover the management of personal data as well as the methods by which people can access it.
9. **Individual Access:** Also, we will endeavor to give clients access to their data when they ask for it. They will have to fill out a form before their information is released or given to them.
10. **Challenging Compliance:** This will help us provide a process for people to contest the organization's PIPEDA compliance, making sure that people can file complaints with ease and that they are resolved quickly and efficiently.

CONCLUSION

These goals and the target capability levels pointed out in the COBIT section are yet to be attained, but with the controls being implemented we will get to our target capability level. We are currently working on each vulnerability and trying to find a long-lasting solution for them without disrupting the business's day-to-day operations.

We created a culture of continuous improvement by consistently integrating feedback and lessons learned into our control procedures to maintain the momentum. Continuous training on the newest IT governance procedures and control systems has been provided to staff members. Keeping abreast of emerging technologies and, where appropriate, integrating them into our control procedures. To reevaluate the efficacy of controls and make the required modifications, periodic reviews will be carried out. For continued support and dedication, we have made it essential to keep stakeholders involved and update them on the control procedures and results. Additionally, we can find areas for development and make sure we try to meet or surpass industry standards by comparing our performance to them.

We also implemented a continuous observation technique, assessment, and modification to maintain the control's efficacy throughout time.